MODELS FOR THREAT INTELLIGENCE

MALWARE ANALYSIS AND INCIDENT FORENSICS

M.Sc. in Cyber Security



SAPIENZA
UNIVERSITÀ DI ROMA



CIS SAPIENZA
CYBER INTELLIGENCE AND INFORMATION SECURITY

WHAT ARE WE LOOKING FOR?

Most dangerous attacks are today characterized by

- Precise targeting
- Use of advanced intrusion/obfuscation techniques
- Full control of target (RAT)
- Long-term persistence (APT)

The attacker (threat) has enough motivations/resources/skills to try to attack its target for prolonged periods of time, using several approaches.

WHAT ARE WE LOOKING FOR?

To better protect against such adversaries we need to know:

- Who they are
- Which goals they have
- How they act against us
- Most effective preventive measures

WHAT ARE WE LOOKING FOR?

To better protect against such adversaries we need to know:

- Who they are
- Which goals they have
- How they act against us
- Most effective preventive measures

Cyber Threat Intelligence is **analysed information** about **adversaries** that reduces the **uncertainty of a specific decision** made by a specific consumer

CYBER THREAT INTELLIGENCE

Here follows what CTI is not:

- **Not a feed**: a subscription that delivers streams of indicators delivers threat data, not intelligence. Nobody analyzed it for you and nobody knew your decisions.
- **Not a tool**: a platform stores and routes intelligence. It does not produce it. Setting up a MISP instance does not create a CTI capability.
- **Not the news**: knowing that a breach happened is awareness. Knowing what it implies for your own exposure is intelligence.
- **Not attribution theatre**: naming a state actor is the most visible output of CTI and almost never the most useful one. Most value is produced far below that level.

CYBER THREAT INTELLIGENCE

The same object (e.g. an IP address) has different meanings depending how much it is processed.

DATA

`185.220.101.47`

- An isolated fact.
- No context, no meaning.
- Supports no decision.

INFORMATION

`Tor exit node, seen in 12 sessions against the VPN portal`

- The fact is placed in context and correlated.
- Useful, but still not actionable

INTELLIGENCE

`Likely credential-stuffing reconnaissance, consistent with campaign X`

- A judgement, with stated uncertainty.
- It changes a decision: enforce MFA on the portal.

CYBER THREAT INTELLIGENCE

Two organizations may interpret in a completely different manner the value of a same piece of data

ORGANISATION A

Blocks the IP

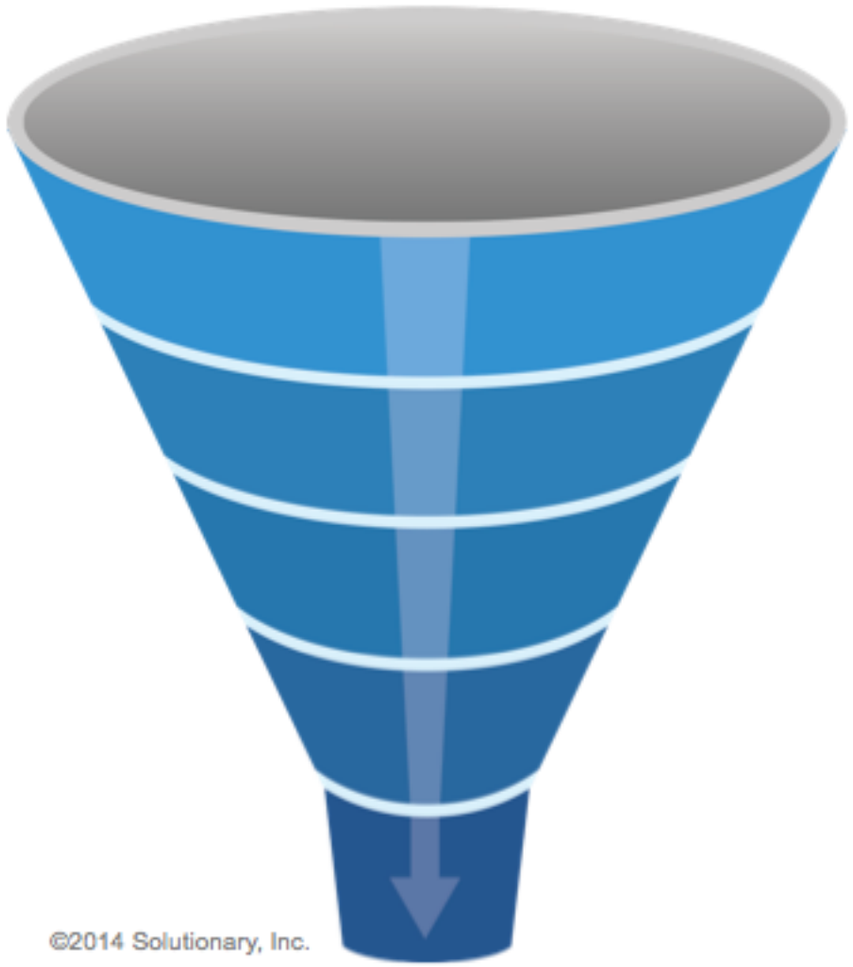
- Ticket closed in four minutes.
- The adversary rotates infrastructure the same day.
- Nothing was learned; the work repeats next week.

ORGANISATION B

Asks who is behind it

- Pivots on the IP and finds nine sibling domains
- Recognizes a campaign that targets its own sector
- Changes an access-control decision, not just a firewall rule.

CYBER THREAT INTELLIGENCE



NOISE
Is comprised of everything that is collected according to Priority Intelligence Requirements (PIR).

DATA
Noise is filtered out/scrubbed. Remaining artifacts are grouped according to defining characteristics.

INFORMATION
Data with a purpose. Once it is assigned a purpose, it becomes information.

INTELLIGENCE
Information with a strategic purpose that can be used to gain advantage. This is exclusively a human centered activity.

ACTIONABLE INTELLIGENCE
Intelligence led, evidenced based assessments that can be initiated and acted upon.

CYBER THREAT INTELLIGENCE

Who makes use of CTI?

Consumer	Decision they take	Product they need	Horizon
SOC L1 / L2	Escalate or close	Enriched, contextualised indicators	Minutes
Incident Response	Contain, scope the intrusion	Actor TTP profile, related indicators	Hours - days
Threat Hunting	Which hypothesis to test	Prioritised TTPs, hunt packages	Days
Detection Engineering	Which detection to write	ATT&CK coverage gap analysis	Weeks
Vulnerability Mgmt	What to patch first	Evidence of active exploitation	Weeks
Red / Purple Team	Which adversary to emulate	Emulation plan	Months
Risk and CISO	Where to invest	Organisational threat profile	Quarters
Board / executives	Budget and priorities	Executive brief, BLUF format	Years
Legal / Compliance	Whether to notify	Dated, factual reconstruction	Legal deadlines

CYBER THREAT INTELLIGENCE

A phishing campaign against the finance department, told to three different consumers.

TACTICAL - TO THE SOC

Block and detect

- Sender domains and URL patterns.
- Attachment hashes and YARA rule.
- Valid for days. Machine readable.

OPERATIONAL - TO IR AND HUNTING

Understand the campaign

- The actor uses OAuth consent phishing, not attachments.
- Post-access behaviour: mailbox rules, forwarding.
- Valid for months. Human readable.

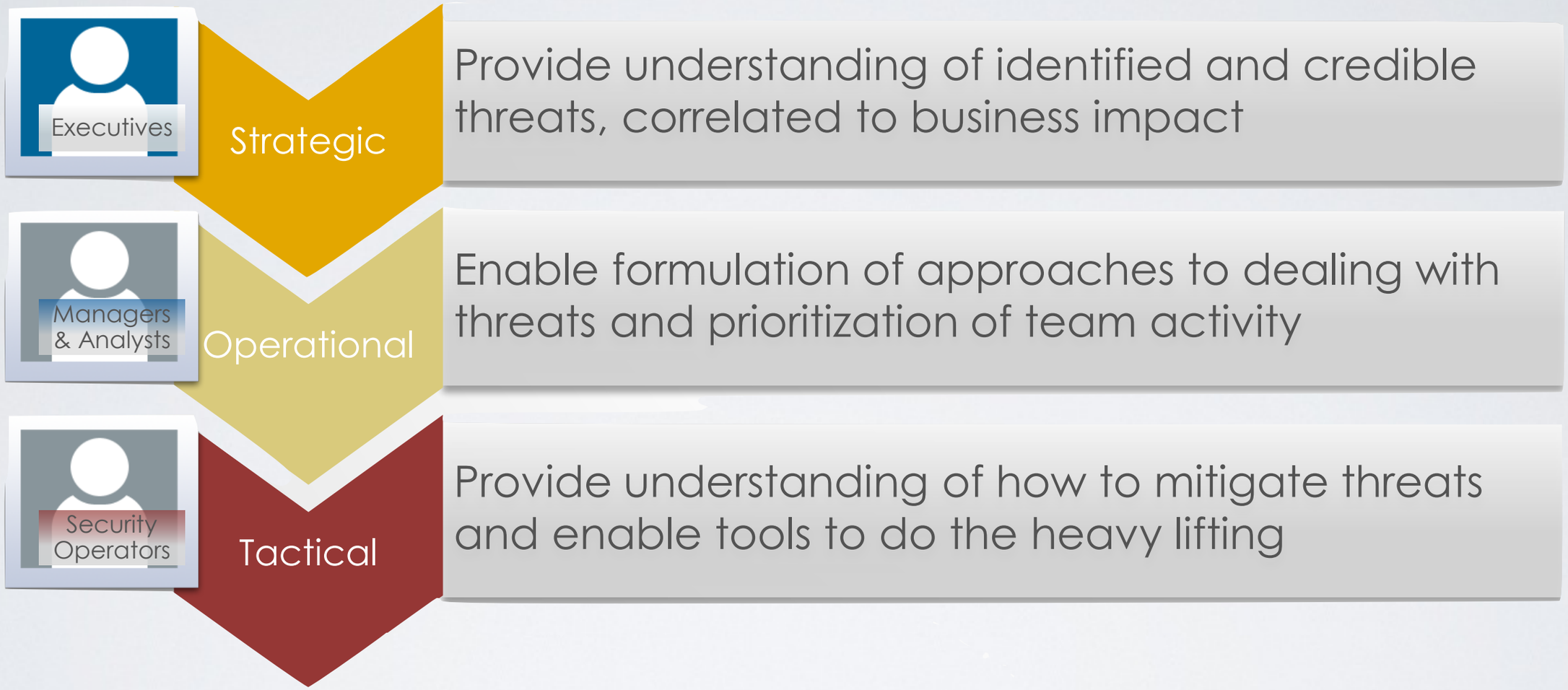
STRATEGIC - TO THE CISO

Decide where to invest

- Our sector is being systematically targeted.
- Identity, not endpoint, is the contested ground.
- Valid for years. Decision oriented.

CYBER THREAT INTELLIGENCE

Goals at several levels:

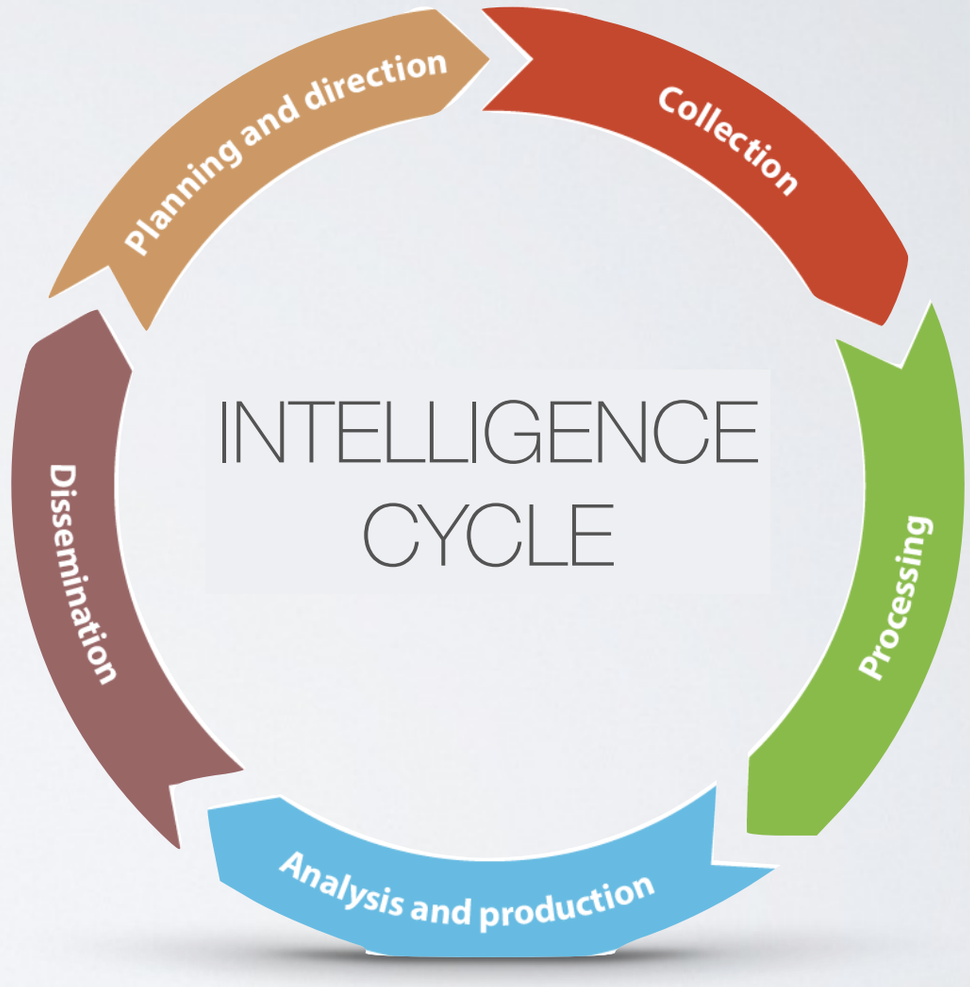


src: http://nova.issa.org/wp-content/uploads/2014/07/iSIGHT-Partners_ISSA-NOVA-v2.pdf

CYBER THREAT INTELLIGENCE

An effective threat intelligence process has the main purpose of characterizing threats in order to identify valuable preventative controls.

- Identify attackers
- Profile attackers
- Identify key tactics
- Rebuild playbook
- Replay playbook
- Utilize results



src: https://blog.nettitude.com/uk/eight-things-to-consider-before-deploying-cyber-threat-intelligence

CYBER THREAT INTELLIGENCE

Each step of the cycle defines inputs and outputs

1. **DIRECTION**
   Decision-makers state what they need to know. Requirements and PIRs are written. A collection plan is produced.

2. **COLLECTION**
   Data is gathered against the plan - internal telemetry, open sources, commercial feeds, sharing communities.

3. **PROCESSING**
   Raw data is made usable: normalised, de-duplicated, translated, enriched, aged.

4. **ANALYSIS**
   Processed information becomes intelligence, using models and structured techniques.

5. **DISSEMINATION**
   The intelligence reaches the consumer in the format and on the timeline they can act on.

6. **FEEDBACK**
   The consumer says whether it helped. Requirements are revised.

PRIORITY INTELLIGENCE REQUIREMENT

A priority intelligence requirement (PIR) is a question whose answer changes a decision that a named person has to make, by a date.

- Must be a question rather than a general topic
  - “Ransomware” is wrong because does not clarify the intent of the requirement
  - “Which of the top five ransomware groups would our EDR fail to detect at initial access?” Is a question with a clear intent
- Must be owned by its consumer
  - The owner defines the PIR -> the CTI team serves the PIR -> the owner consumes the outputs
- Must be bound to a decision
  - A PIR with no bounded decision produces non-actionable intelligence
- Must be bound in time
  - Only timed decisions are useful

PRIORITY INTELLIGENCE REQUIREMENT

Level	What it is	Example	Written by
IR Intelligence Requirement	A broad topic the organisation needs to understand	Understand threats to our European payment operations	CTI lead with stakeholders
PIR Priority Intelligence Req.	A prioritised, decision-linked question with a deadline	Which ransomware groups have targeted EU payment processors in the last 12 months, and how do they gain initial access?	CTI lead, approved by consumer
SIR Specific Intelligence Req.	A sub-question that partly answers a PIR	Which of those groups use valid accounts for initial access?	Analyst
EEI Essential Elements of Info.	The concrete observable to be collected	Leak-site victim lists, IR reports, IAB listings for our sector	Analyst / collector

PRIORITY INTELLIGENCE REQUIREMENT

A good PIR has five properties:

- **Tied to a decision** - You can name the decision it informs and the person who makes it.
- **Specific** - Bounded by sector, geography, technology or time.
- **Answerable** - With the data you have or can realistically obtain.
- **Time-bound** - It has a deadline, because the decision has one.
- **Falsifiable**: It is possible to state what evidence would settle it - including evidence that would contradict the expected answer.

PRIORITY INTELLIGENCE REQUIREMENT

Writing effective PIRs facilitates the CTI job

POORLY WRITTEN

- What are the current cyber threats?
- Is APT29 a threat to us?
- Monitor the dark web.
- Are we secure against ransomware?
- Give us intelligence on our supply chain.

WELL FORMED

- Which threat actors have targeted EU retail payment processors since January 2026, and by what initial access vector?
- Has any actor using the TTPs attributed to APT29 been observed against organisations running our identity stack, in the last 18 months?
- Are credentials belonging to our domains being offered on infostealer log markets, and at what volume, month by month?
- Which of the top five ransomware groups by victim count would our current EDR coverage fail to detect at the initial-access stage?
- Which of our 20 most critical suppliers have disclosed a breach or appeared on a leak site in the past 24 months?

PRIORITY INTELLIGENCE REQUIREMENT

PIRs may come from different sources

- **Crown jewel analysis** - What would actually hurt if it were lost, leaked or stopped?
- **Threat modelling of the organisation** - Sector, geography, size, technology stack, public profile, partners. These determine who is plausibly interested in you.
- **Lessons from past incidents** - Your own incident history is the most under-used source of requirements in almost every organisation.
- **Stakeholders** - Ask what decision they are struggling with. Most will not know what to ask for until you ask them.

PRIORITY INTELLIGENCE REQUIREMENT

A common error:

> *Most CTI teams collect what is easy to collect and then look for a question it might answer.*

The symptom is measurable: indicator volume rises quarter on quarter, and no stakeholder can name a decision that was drive by CTI outputs.

DATA COLLECTION

Sources taxonomy

Source	What it gives you	Strength	Weakness
Internal telemetry	What actually happened to you	Ground truth, high relevance	Limited to your visibility
Own incident history	Who has already targeted you	Most predictive source you have	Small sample, often undocumented
Sharing communities	Peer observations, early warning	Sector relevance, trust	Requires reciprocity and effort
Vendor reporting	Deep analysis of actors and campaigns	Expertise, scale of telemetry	Marketing incentive, naming chaos
Open feeds	Indicators at volume	Free, immediate	Noisy, stale, rarely contextualised
Commercial feeds	Curated indicators, finished reporting	Coverage, SLA	Cost; overlap; opaque methodology
Underground / dark web	Access brokers, leaks, chatter	Early signal on intent	Legal and ethical exposure
Honeypots, sinkholes, scanning	Adversary infrastructure at scale	Original observation	Operational cost

DATA COLLECTION

Right before analysis data needs to be preprocessed:

- **Normalisation** - One representation per object type. Defanged indicators, consistent timestamps in UTC, consistent actor naming.
- **De-duplication** - The same indicator may arrive from several feeds. De-duplication allows keeping metrics clean.
- **Enrichment** - Geolocation, WHOIS, passive DNS, reputation, first and last seen. Enrichment is what turns data into information.
- **Ageing and decay** - An indicator is not true forever. A decay model reduces confidence over time and eventually retires the indicator automatically.
- **Quality control** - Feeds contain the defender's own sinkholes, public DNS resolvers and CDN addresses.

CYBER THREAT INTELLIGENCE

How do we make intelligence “actionable”?

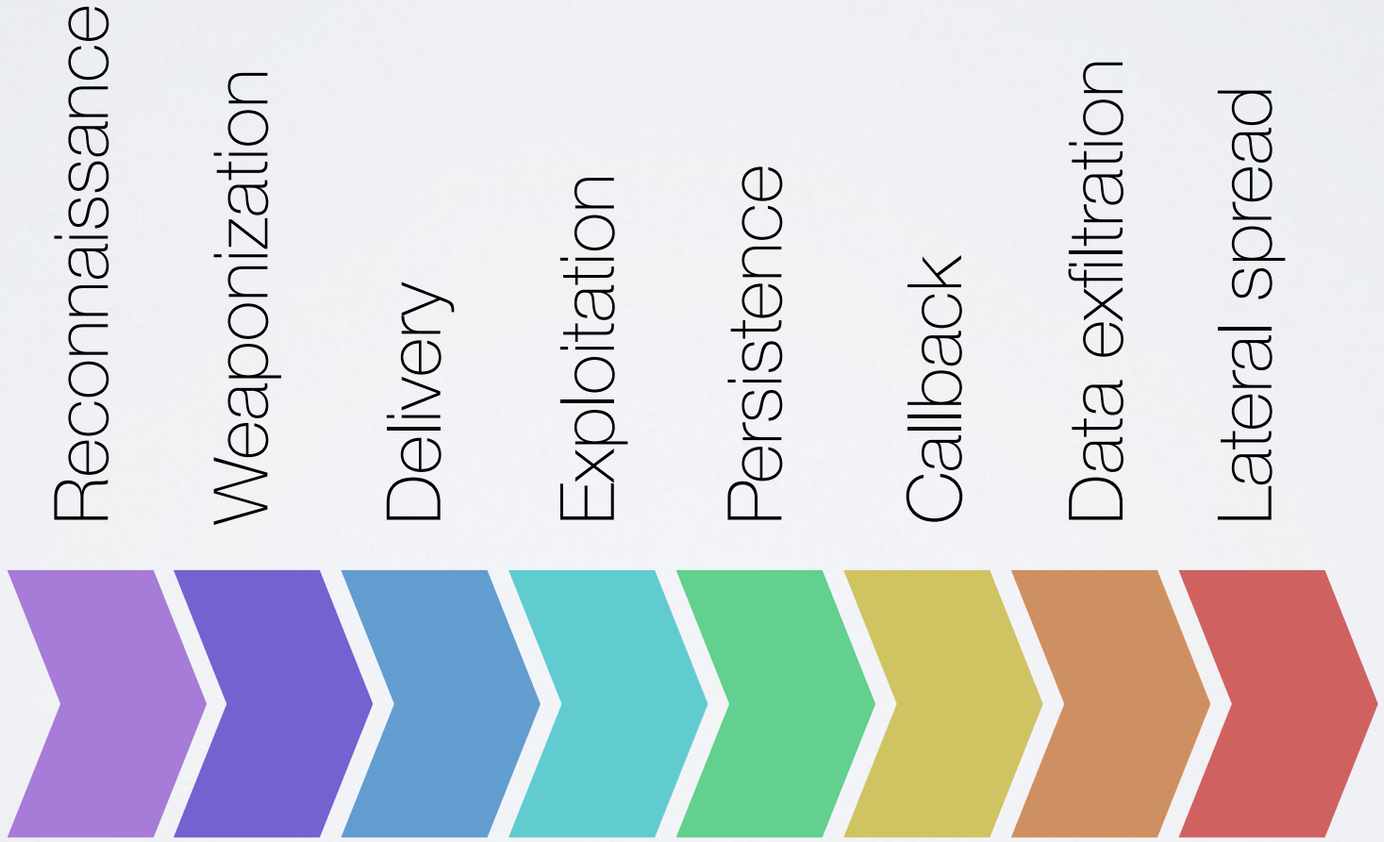
- Attackers determine the least costly and most valuable attacks based on
  - Who the targets are
  - Required success rate
  - Speed of conversion

Inexpensive, valuable, scalable, or repeatable:	**Costly, valueless, unscalable, or unrepeatable:**
Phishing	Web vulnerabilities
Credential reuse	0-day exploits
Known vulnerabilities with public exploits	Known vulnerabilities without public exploits
Office macros	Embedded devices
Spyware	Crypto weaknesses
Vendor compromise	Insider threat

INTRUSION KILL CHAIN

The kill chain is not just a way to represent attacks, but rather a methodology to analyse (tentatives of) intrusions to extract actionable information (intelligence).

Hutchins et al. “Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains”, Leading Issues in Information Warfare & Security Research 1.1 (2011)



INDICATORS

The fundamental element of intelligence in this model is the indicator

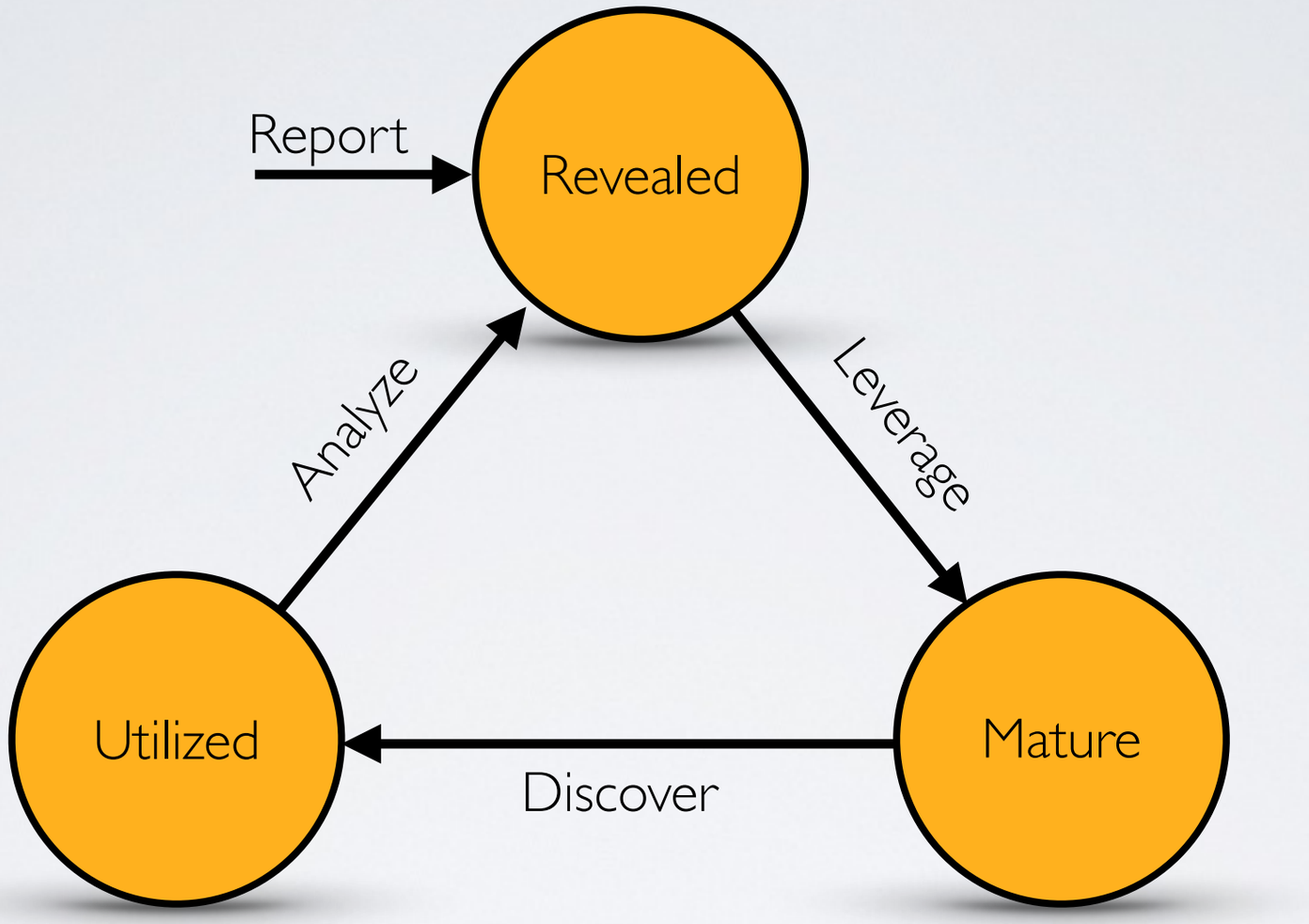
- **Indicator**: any piece of information that objectively describes an intrusion

Three types of indicators

- Atomic - those which cannot be broken down into smaller parts and retain their meaning in the context of an intrusion. (e.g. IP addresses, email addresses, vulnerability identifiers, etc.)
- Computed - those which are derived from data involved in an incident. (e.g. hash values)
- Behavioral - collections of computed and atomic indicators, often subject to qualification by quantity and possibly combinatorial logic. (e.g. “the intruder initially used a backdoor which generated network traffic matching [regular expression] at the rate of [some frequency] to [some IP address]”)

INDICATORS

Life cycle



THE PYRAMID OF PAIN

Types of indicators

- **Hash Values**: SHA1, MD5 or other similar hashes that correspond to specific suspicious or malicious files. Often used to provide unique references to specific samples of malware or to files involved in an intrusion.
- **IP Addresses**: IP address or netblocks referring to the attacker.
- **Domain Names**: this could be either a domain name itself (e.g., "evil.net") or maybe even a sub- or sub-sub-domain (e.g., "this.is.sooooo.evil.net")
- **Network Artifacts**: observables caused by adversary activities on your network. In practice this really means those pieces of the activity that might tend to distinguish malicious activity from that of legitimate users. Typical examples might be URI patterns, C2 information embedded in network protocols, distinctive HTTP User-Agent or SMTP Mailer values, etc.

THE PYRAMID OF PAIN

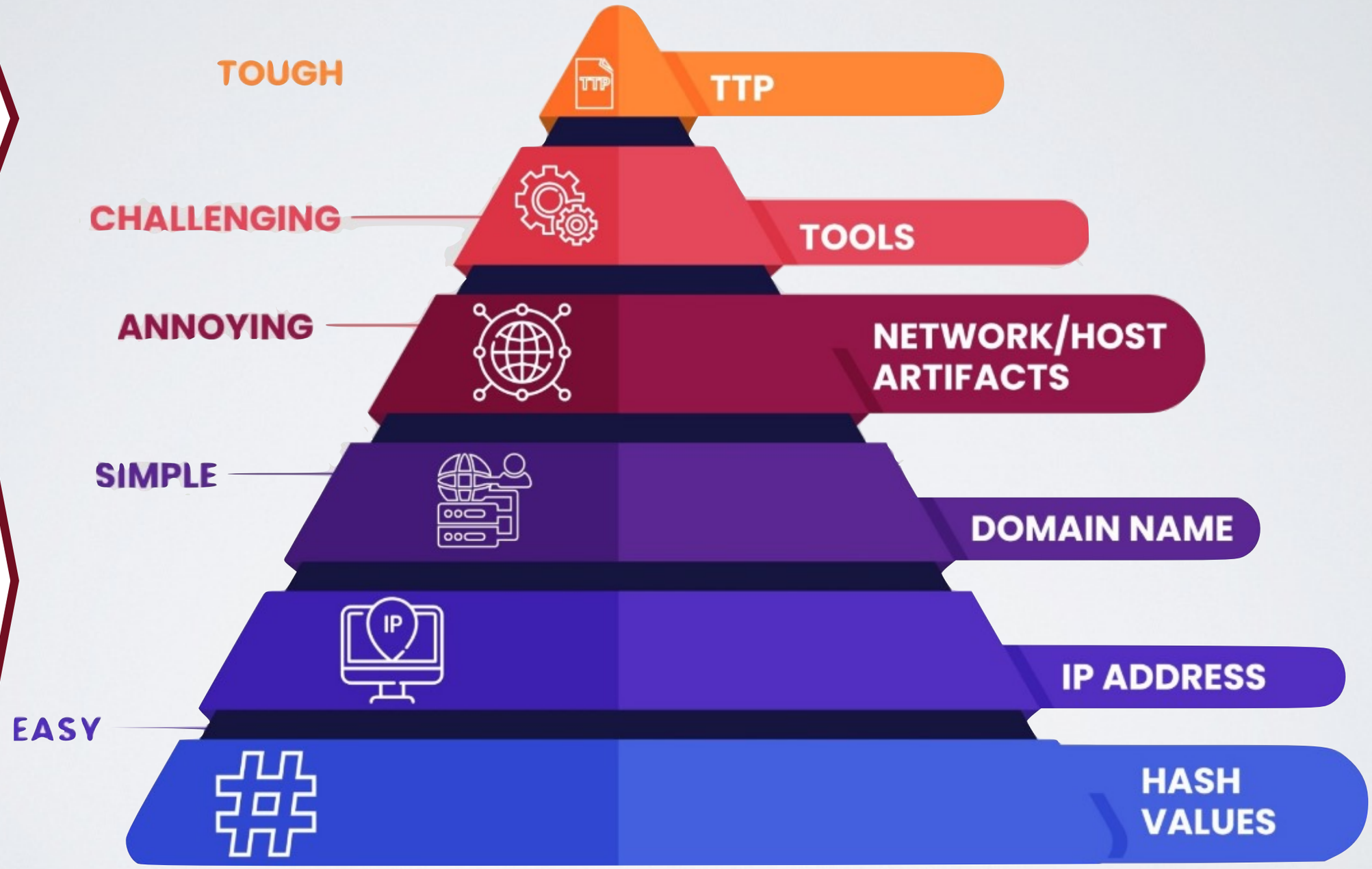
Types of indicators

- **Host Artifacts**: observables caused by adversary activities on one or more of your hosts. They could be registry keys or values known to be created by specific pieces of malware, files or directories dropped in certain places or using certain names, names or descriptions or malicious services…
- **Tools**: software used by the adversary to accomplish their mission. Mostly this will be things they bring with them, rather than software or commands that may already be installed on the computer.
- **Tactics, Techniques and Procedures (TTPs)**: how the adversary goes about accomplishing their mission, from reconnaissance all the way through data exfiltration and at every step in between. "Dumping cached authentication credentials and reusing them in Pass-the-Hash attacks" would be a TTP.

THE PYRAMID OF PAIN

IOA

IOC



INTRUSION KILL CHAIN

Indicators can be used to describe/identify various stages of the intrusion using the kill chain as a reference model

Phase	Indicators
Reconnaissance	
Weaponization	
Delivery	
Exploitation	
Installation	C:\...\fssm32.exe
C2	
Actions on Objectives	

RECONSTRUCT THE KILL CHAIN

The first IoC you recover is oftentimes in the middle of the chain

1. **Anchor**
   Place the observation you have on the chain. An implant hash is "installation"; a beacon is "C2".

2. **Work backwards**
   What must have been true for this to happen? Installation implies exploitation implies delivery.

3. **Work forwards**
   What comes next if the adversary is not stopped? This is what you hunt for now.

4. **Mark the gaps**
   Every phase you cannot evidence is either a collection gap or a step that did not happen. Decide which, and say so.

5. **Extract indicators**
   For every phase, record what you can recognise again - and at what level of the pyramid it sits.

RECONSTRUCT THE KILL CHAIN

Indicators can be used to describe/identify various stages of the intrusion using the kill chain as a reference model

Phase	Indicators
Reconnaissance	[Recipient List] Benign File: tcnom.pdf
Weaponization	Trivial encryption algorithm: Key 1
Delivery	dn...etto@yahoo.com Downstream IP: 60.abc.xyz.215 Subject: AIAA Technical Committees [Email body]
Exploitation	CVE-2009-0658 [shellcode]
Installation	C:\...\fssm32.exe C:\...\IEUpd.exe C:\...\IEXPLORE.hlp
C2	202.abc.xyz.7 [HTTP request]
Actions on Objectives	N/A

COURSE OF ACTION

The intrusion kill chain becomes a model for actionable intelligence when defenders align enterprise defensive capabilities to the specific processes an adversary undertakes to target that enterprise

Action	Intent
Detect	Know that it is happening
Deny	Prevent it from happening
Disrupt	Make it stop mid-course
Degrade	Make it slower or less effective
Deceive	Make the adversary act on false information
Destroy	Remove the adversary's capability

COURSE OF ACTION

The intrusion kill chain becomes a model for actionable intelligence when defenders align enterprise defensive capabilities to the specific processes an adversary undertakes to target that enterprise

Phase	Detect	Deny	Disrupt	Degrade	Deceive	Destroy
Reconnaissance	Web analytics	Firewall ACL				
Weaponization	NIDS	NIPS				
Delivery	Vigilant user	Proxy filter	In-line AV	Queuing		
Exploitation	HIDS	Patch	DEP			
Installation	HIDS	“chroot” jail	AV			
C2	NIDS	Firewall ACL	NIPS	Tarpit	DNS redirect	
Actions on Objectives	Audit log			Quality of Service	Honeypot	

COURSE OF ACTION

Measure effectiveness to drive defense strategies over time!

	December	March	June
Reconnaissance			
Weaponization	◇	→	◇
Delivery	◆	→	◆
Exploitation	→ ◆	→	◆
Installation	◆ →	◆ →	◆
C2	◆ →	◆ →	◆
Actions on Objectives			

Legend ◇ *Detection* ◆ *Mitigation* → *Leverage new indicators*

RECONSTRUCT THE KILL CHAIN

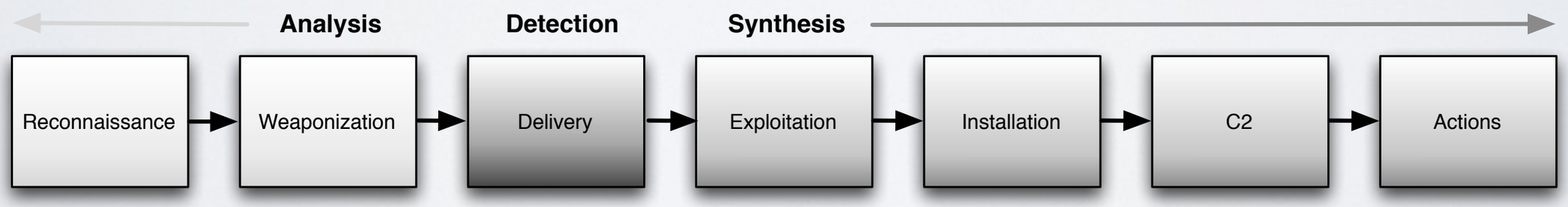
Improved protection affects the course of actions

Late phase detection





Early phase detection



INVESTIGATE CAMPAIGNS

Recurring attacks from persistent threats require deeper understandings.

- **Tabulate intrusions side by side**: one column per intrusion, one row per phase, indicators in the cells.
- **Look repeated IoCs**: columns will differ in most cells. Those that match across intrusions are potential adversary's invariants.
- **Weight by cost of change**: a shared IP proves little. A shared C2 protocol quirk, a shared packer, a shared operating approach proves a great deal.
- **Beware of shared infrastructure**: Two unrelated actors using the same bulletproof host or the same commodity RAT are not the same actor.
- **Produce a campaign hypothesis**: Stated as a hypothesis, with confidence, and with what evidence would falsify it.

INVESTIGATE CAMPAIGNS

Recurring attacks from persistent threats require deeper understandings.

RECONSTRUCT THE KILL CHAIN

Indicators can be used to describe/identify various stages of the intrusion using the kill chain as a reference model

Phase	Indicators
Reconnaissance	[Recipient List] Benign File: tcnom.pdf
Weaponization	Trivial encryption algorithm: Key 1
Delivery	dn...etto@yahoo.com Downstream IP: 60.abc.xyz.215 Subject: AIAA Technical Committees [Email body]
Exploitation	CVE-2009-0658 [shellcode]
Installation	C:\...\fssm32.exe C:\...\IEUpd.exe C:\...\IEXPLORE.hlp
C2	202.abc.xyz.7 [HTTP request]
Actions on Objectives	N/A

INVESTIGATE CAMPAIGNS

Recurring attacks from persistent threats require deeper understandings.

Phase	Intrusion 1	Intrusion 2
Reconnaissance	[Recipient List] Benign File: tcnom.pdf	[Recipient List] Benign File: MDA_Prelim_09.pdf
Weaponization	Trivial encryption algorithm: Key 1	
Delivery	Downstream IP: 60.abc.xyz.215 Subject: AIAA Technical Committees [Email body]	Downstream IP: 216.abc.xyz.76 Subject: 7th Annual U.S. Missile Defense Conference [Email body]
	dn...etto@yahoo.com	
Exploitation	CVE-2009-0658 [shellcode]	
Installation	C:\...\fssm32.exe C:\...\IEUpd.exe C:\...\IEXPLORE.hlp	
C2	202.abc.xyz.7 [HTTP request]	
Actions on Objectives	N/A	N/A

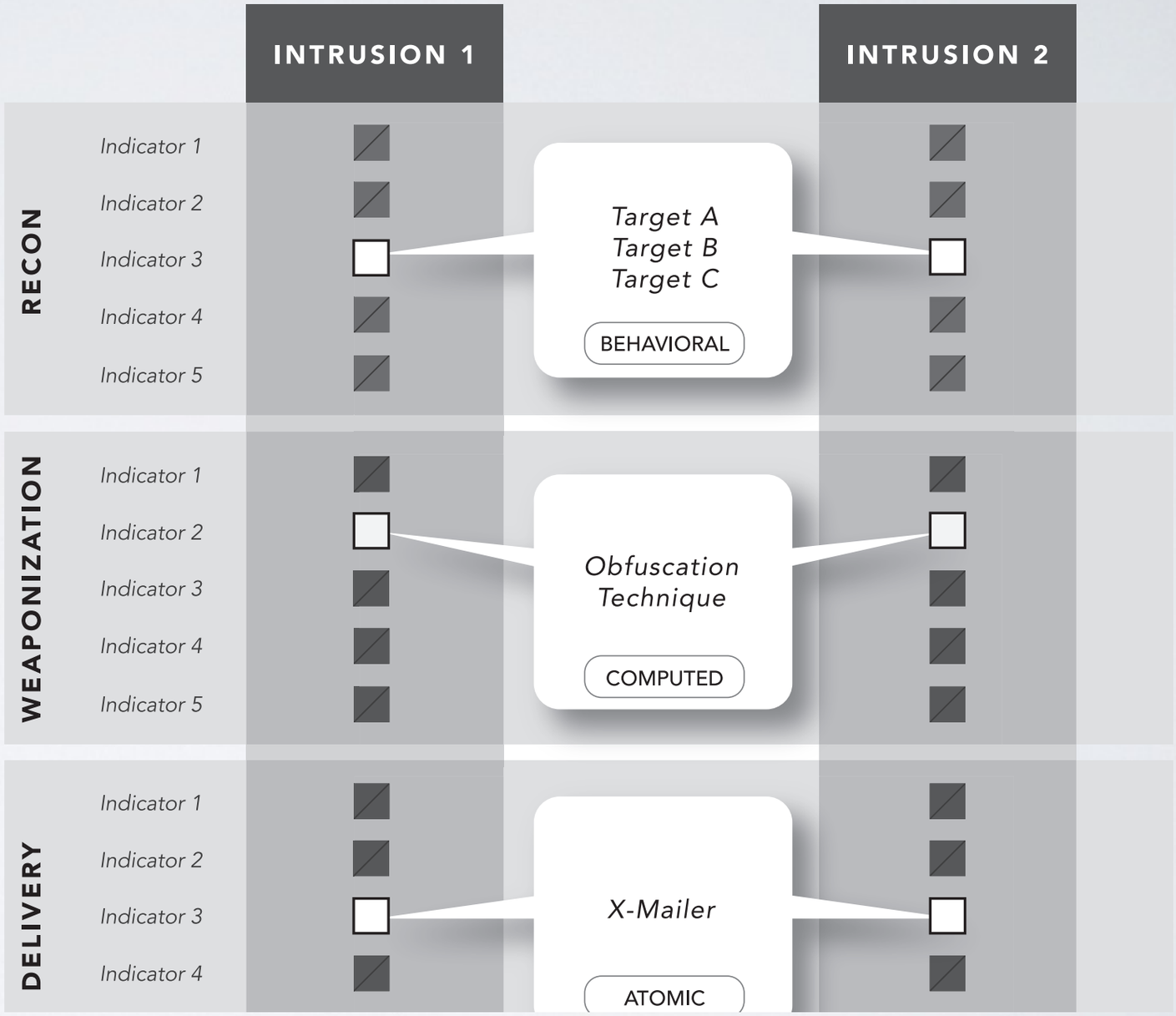
INVESTIGATE CAMPAIGNS

Recurring attacks from persistent threats require deeper understandings.

Phase	Intrusion 1	Intrusion 2	Intrusion 3
Reconnaissance	[Recipient List] Benign PDF	[Recipient List] Benign PDF	[Recipient List] Benign PPT
Weaponization	Trivial encryption algorithm		
	Key 1		Key 2
Delivery	[Email subject] [Email body]	[Email subject] [Email body]	[Email subject] [Email body]
	dn...etto@yahoo.com		ginette.c...@yahoo.com
	60.abc.xyz.215	216.abc.xyz.76	
Exploitation	CVE-2009-0658 [shellcode]		[PPT 0-day] [shellcode]
Installation	C:\...\fssm32.exe C:\...\IEUpd.exe C:\...\IEXPLORE.hlp		
C2	202.abc.xyz.7 [HTTP request]		
Actions on Objectives	N/A	N/A	N/A

INVESTIGATE CAMPAIGNS

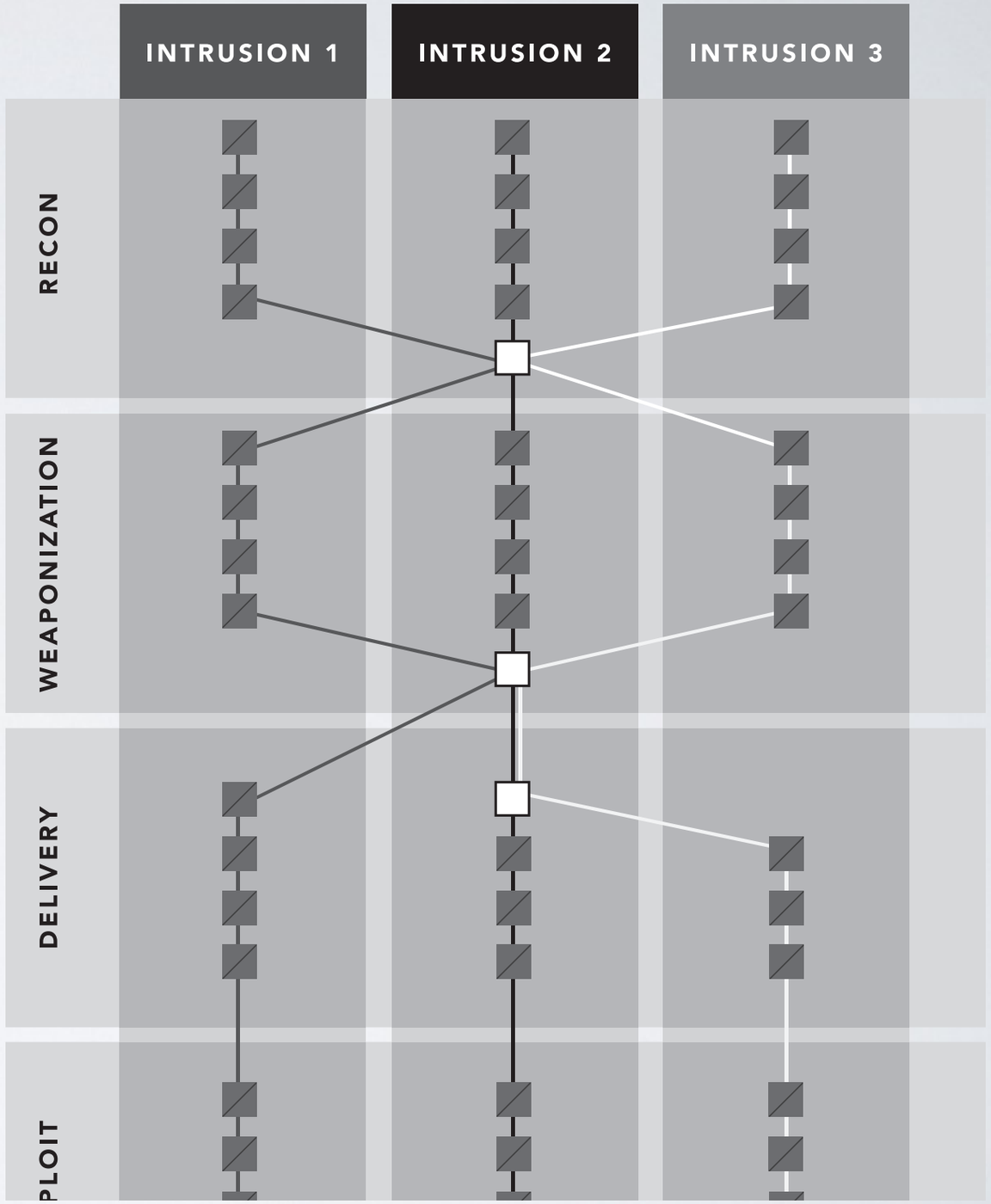
Compare intrusion indicators to find commonalities



INVESTIGATE CAMPAIGNS

Inflection points among diverse intrusions may represent common patterns in a long-term campaign

Such patterns can be used to uniquely identify threat actors



CKC USAGE SCENARIOS

The analysis have practical uses:

COVERAGE ASSESSMENT

Where do my controls cluster, and where are they thin?

EFFECTIVENESS SCORECARD

Which phase did we actually detect, on each past intrusion?

POST-MORTEM STRUCTURE

What did we miss, and at which phase could we have stopped it?

INVESTMENT PLANNING

Which capability gap costs us the most earliest?

LIMITS

A tool that is not perfectly suited to all uses:

- User centric
- Low-level description of observables (events)
- Too focussed on malware-based attacks
- Several variants
- Attackers do not always follow a playbook

THE DIAMOND MODEL

This model guides the analysis process through several predefined steps that starting from indicators, strive to identify high-level facts about the security incidents that are analysed

- Describes security **events** (incidents) through few basic aspects
- Connects events that took place in a single intrusion through **activity threads**
- Identifies commonalities among activity threads forming **activity groups** that can then be used for strategic planning

Sergio Caltagirone, Andrew Pendergast, and Christopher Betz, "Diamond Model of Intrusion Analysis," Center for Cyber Threat Intelligence and Threat Research, Hanover, MD, Technical Report ADA586960, 05 July 2013

THE DIAMOND MODEL

The model represent “events” (intrusion) as a set of **core features** pertaining to few fundamental aspects

For every intrusion event there exists an adversary taking a step towards an intended goal by using a capability over infrastructure against a victim to produce

An event defines discrete time-bound activity restricted to a specific phase

The adversary may require access to further external resources to reach its goal (**meta features**).

THE DIAMOND MODEL

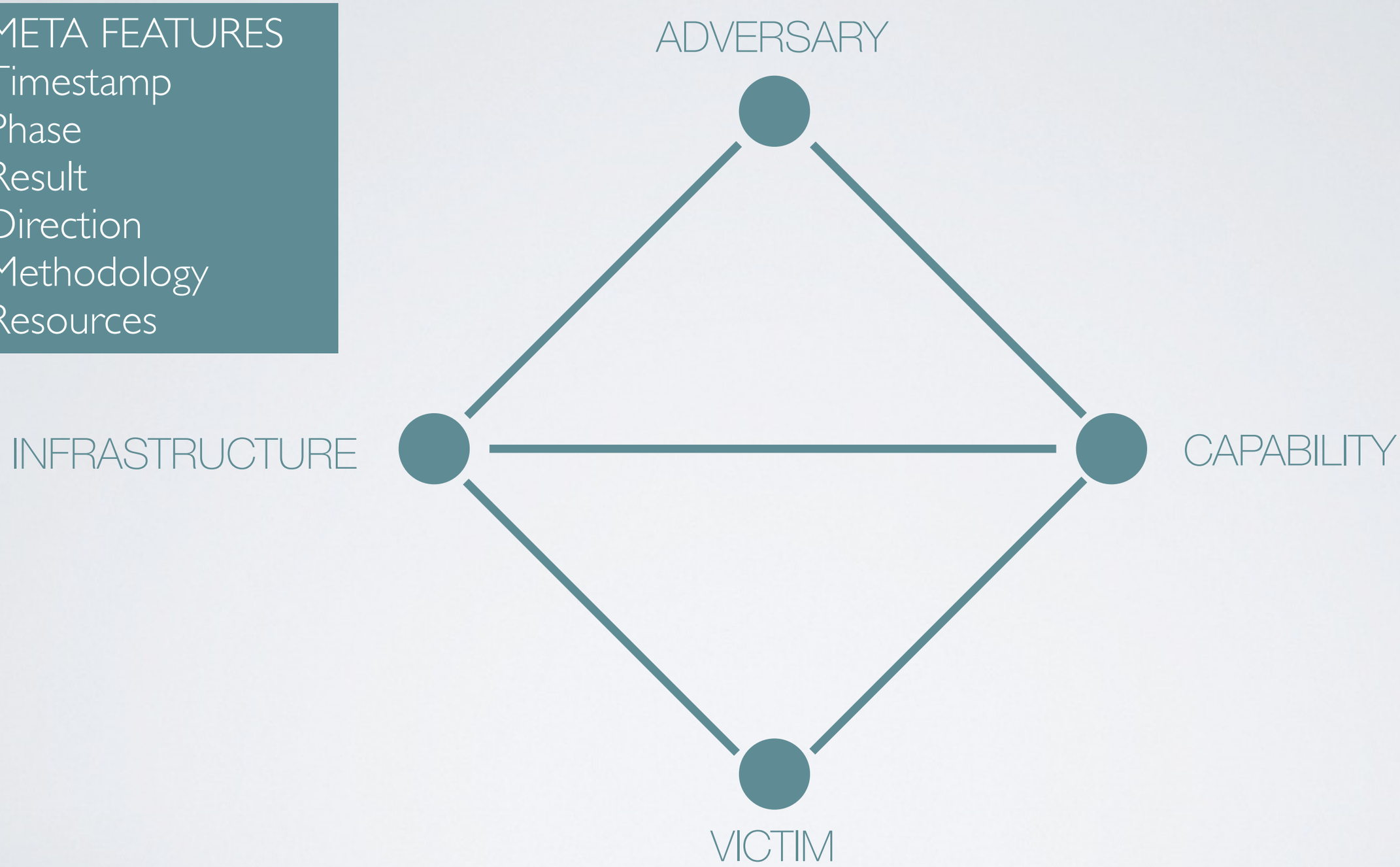
Elements can be further break down to detail them

$$
\begin{aligned}
\boldsymbol{E} = \langle & \langle Adversary, Confidence_{adversary} \rangle, \\
& \langle Capability, Confidence_{capability} \rangle, \\
& \langle Infrastructure, Confidence_{infrastructure} \rangle, \\
& \langle Victim, Confidence_{victim} \rangle, \\
& \langle Timestamp_{start}, Confidence_{timestamp_{start}} \rangle, \\
& \langle Timestamp_{end}, Confidence_{timestamp_{end}} \rangle, \\
& \langle Phase, Confidence_{phase} \rangle, \\
& \langle Result, Confidence_{result} \rangle, \\
& \langle Direction, Confidence_{direction} \rangle, \\
& \langle Methodology, Confidence_{methodology} \rangle, \\
& \langle Resources, Confidence_{resources} \rangle \rangle
\end{aligned}
\longrightarrow =
$$

$$
\begin{aligned}
& \langle \langle Organization, Confidence_{organization} \rangle, \\
& \langle HostIPAddress, Confidence_{IP} \rangle, \\
& \langle Hostname, Confidence_{Hostname} \rangle, \\
& \langle Application, Confidence_{Application} \rangle, \\
& \langle TCPPort, Confidence_{TCPPort} \rangle \rangle
\end{aligned}
$$

THE DIAMOND MODEL

META FEATURES
Timestamp
Phase
Result
Direction
Methodology
Resources



THE DIAMOND MODEL

ADVERSARY: actor/organisation responsible for utilising a capability against the victim to achieve their intent.

- **Adversary Operator** - the actual “hacker” or person(s) conducting the intrusion activity.
- **Adversary Customer** - the entity that stands to benefit from the activity conducted in the intrusion. It may be the same as the adversary operator, or it may be a separate person or group.

THE DIAMOND MODEL

CAPABILITY: tools and/or techniques of the adversary used in the event

- **Capability Capacity** - all of the vulnerabilities and exposures that can be utilised by the individual capability regardless of victim are considered its capacity.
- **Adversary Arsenal** - the adversary's complete set of capabilities, and therefore the combined capacities of their individual capabilities.

The C&C typically represent a specific kind of capability used by the adversary.

THE DIAMOND MODEL

INFRASTRUCTURE: describes the physical and/or logical communication structures the adversary uses to deliver a capability, maintain control of capabilities and effect results from the victim.

- **Directly controlled** infrastructure
- Infrastructure controlled by an **intermediary**
- **Public infrastructure** providers

THE DIAMOND MODEL

VICTIM: target of the adversary and against whom vulnerabilities and exposures are exploited and capabilities used.

- **Persona**: and individual or organization being targeted
- **Asset**: the attack surface and consist of the set of networks, systems, hosts, email addresses, IP addresses, social networking accounts, etc. against which the adversary directs their capabilities.

The set of vulnerabilities and exposures of a victim susceptible to exploitation is referred to as the victim susceptibilities

- They are sub-features of the victim

THE DIAMOND MODEL

META FEATURES

- Timestamp: date and/or time when the event occurred. May include start/end timestamps
- Phase: represents the specific logical role played by the event in an activity thread
  - You may want to stick with the cyber kill chain jargon for phases
- Results: post-conditions of an adversary's operations
  - Qualitative: <Success,Failure,Unknown>
  - Informative: Confidentiality|Integrity|Availability-compromised
  - Details: refer to the specific compromised assets

THE DIAMOND MODEL

META FEATURES

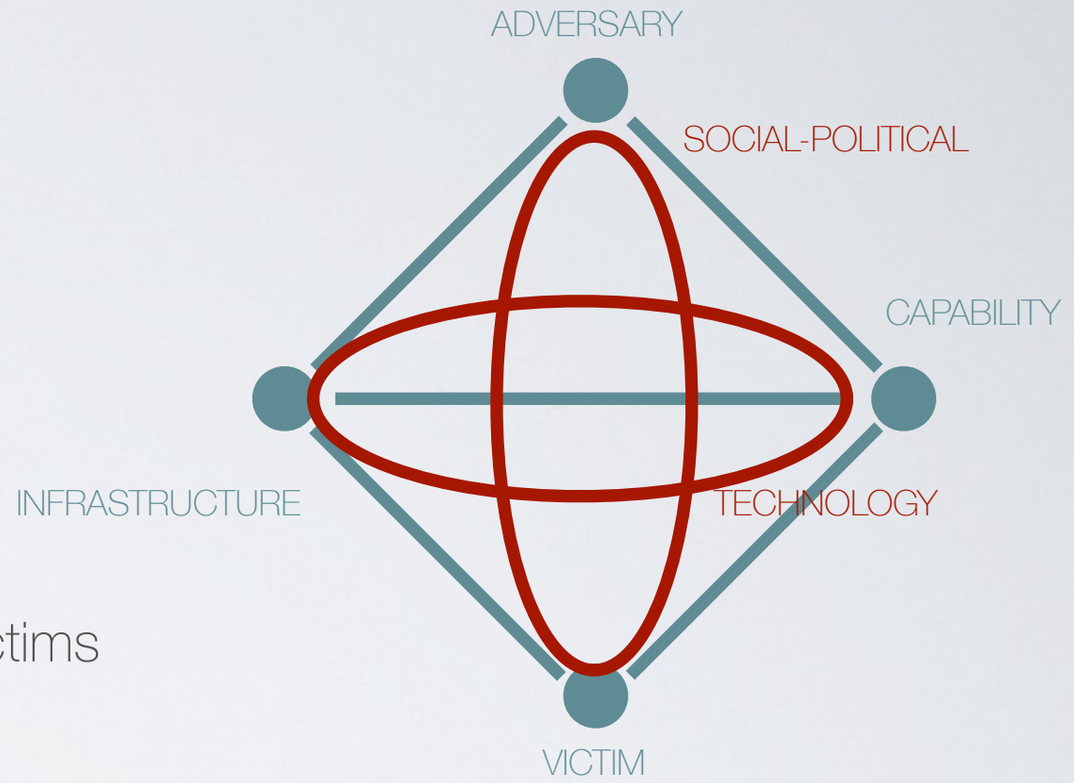
- Direction: describes qualitatively the main direction for actions in the event
  - Victim-to-Infrastructure, Infrastructure-to-Victim, Infrastructure-to-Infrastructure, Adversary-to-Infrastructure, Infrastructure-to-Adversary, Bidirectional, or Unknown
- Methodology: description of the general class of activity
  - E.g.: spear-phish email, content-delivery attack, syn flood, etc.
  - Better use an existing taxonomy
- Resources: all supporting elements on which the event, and therefore each core- and meta-feature, depends
  - E.g.: software, knowledge, information, hardware, funds, facilities, access

Meta features can be expanded

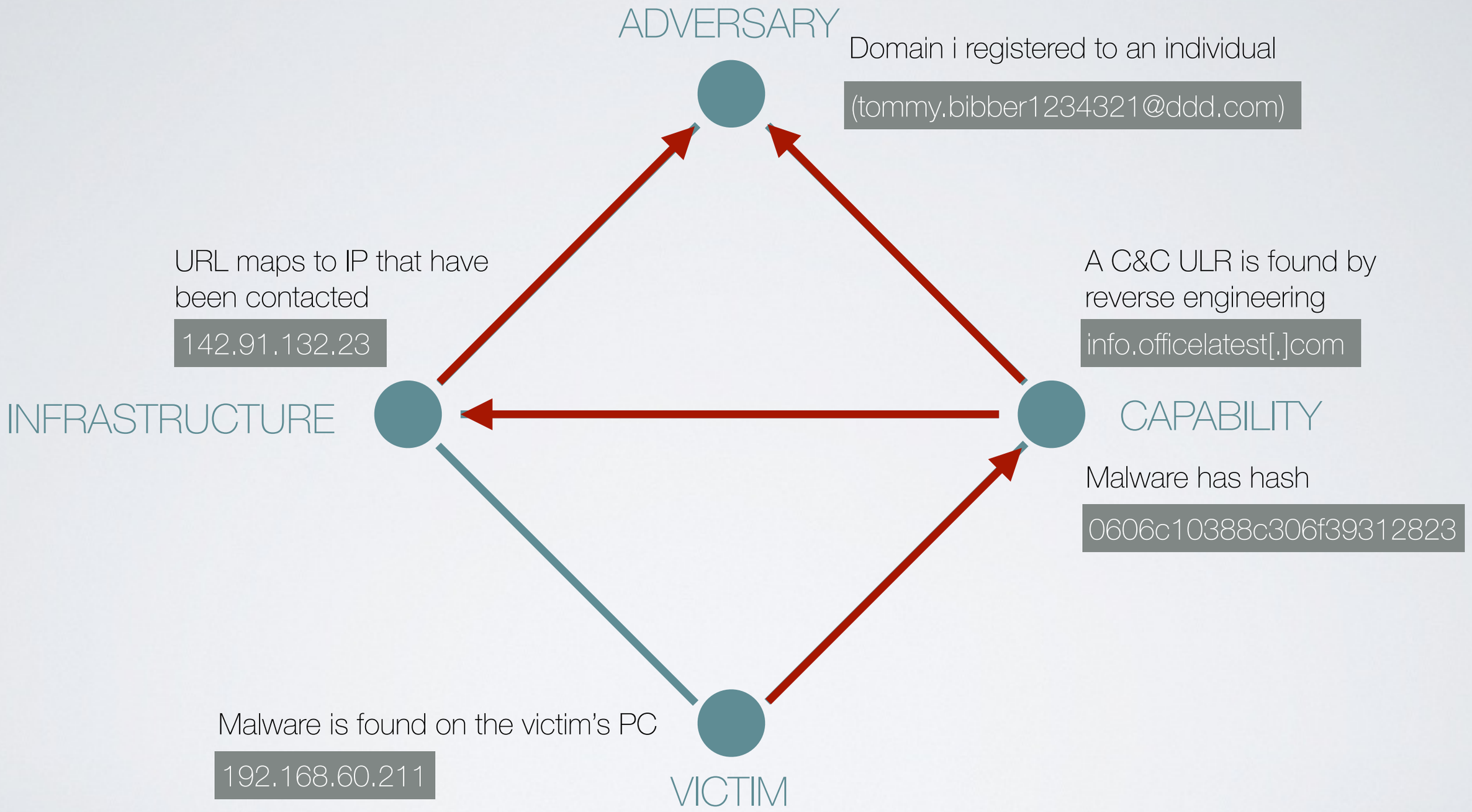
THE DIAMOND MODEL

Two useful feature extensions:

- SOCIAL-POLITICAL
  - Describes the relationship existing between the Adversary and its Victims
    - Intent
    - Persistence
  - Useful to defined a shared threat-space with other victims
- TECHNOLOGY
  - Describes the technology connecting and enabling the infrastructure and the capability to operate and communicate.



ANALYTICAL PIVOTING

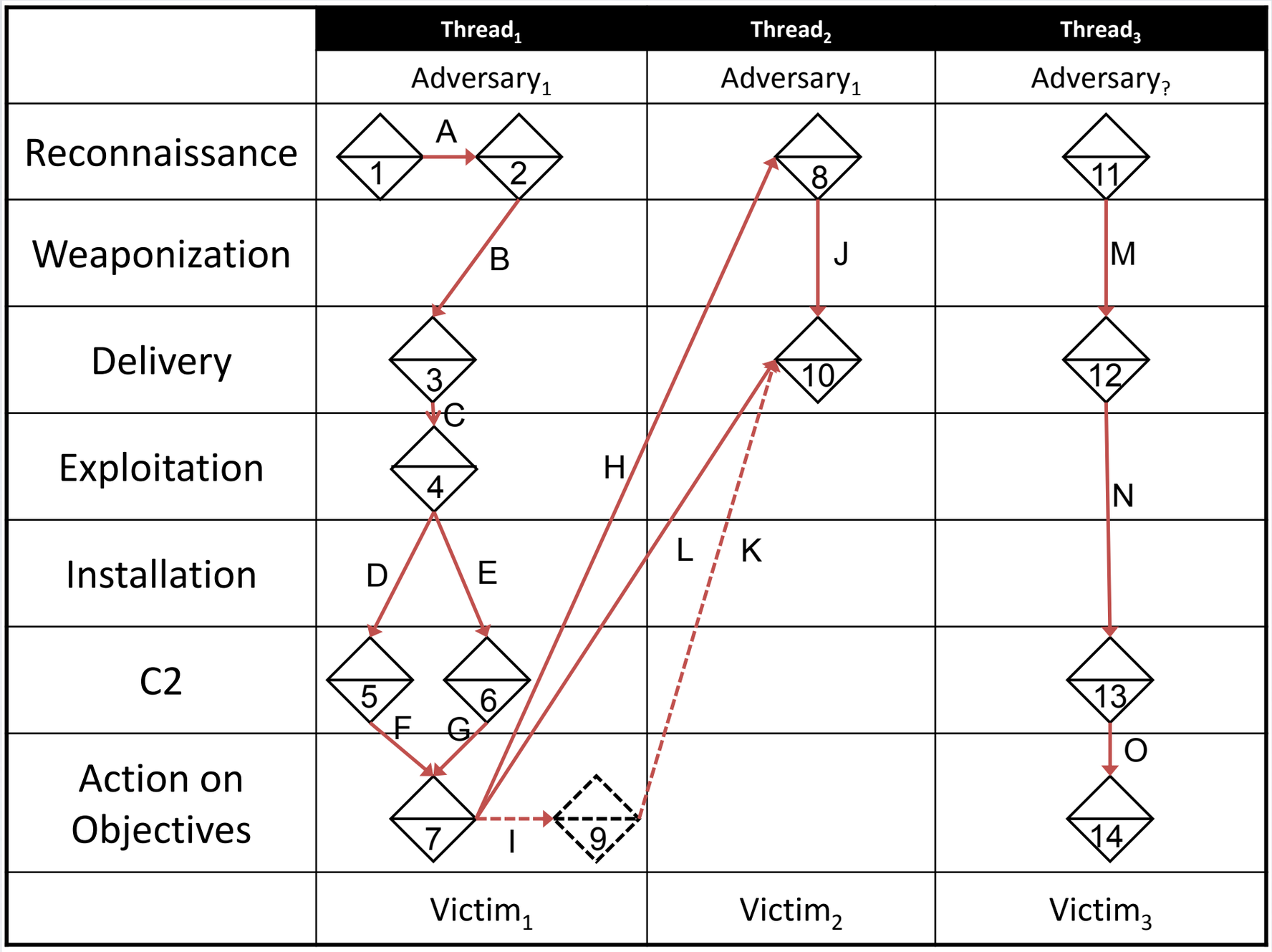


ANALYTICAL PIVOTING

Different approaches:

- **Victim-centered**: analyzing data related to a potential victim reveals the other related (and Diamond-connected) elements: malicious capabilities and infrastructure.
- **Capability-centered**: exploits features of a capability to discover those other related elements like (i) victims whom that capability is used against, (ii) infrastructure supporting the capability, (iii) technology enabling the capability, (iv) clues to other related capabilities, (v) and (possible) clues to the adversary.
- **Infrastructure-centered**: focuses on the malicious infrastructure of the adversary. From this element other related elements can be discovered. Difficult access.
- **Adversary-centered**: mostly reserved to law-enforcement agencies.

ACTIVITY THREAD



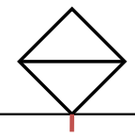
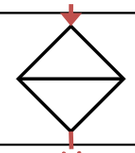
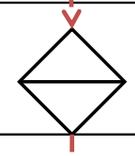
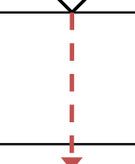
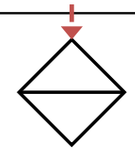
ACTIVITY THREAD

- **Vertical correlation**
  - Identify knowledge gaps
  - Fill those gaps with new knowledge
  - Establish causal relationships among events
- **Horizontal correlation**
  - The analytic process of causally linking events between vertical threads across adversary-victim pairs
  - identify common knowledge gaps between threads
  - use knowledge from one thread to fill knowledge gap in another
  - Identify common features across victims which can lead to the creation of an activity group

ACTIVITY THREAD

Identify Adversary processes

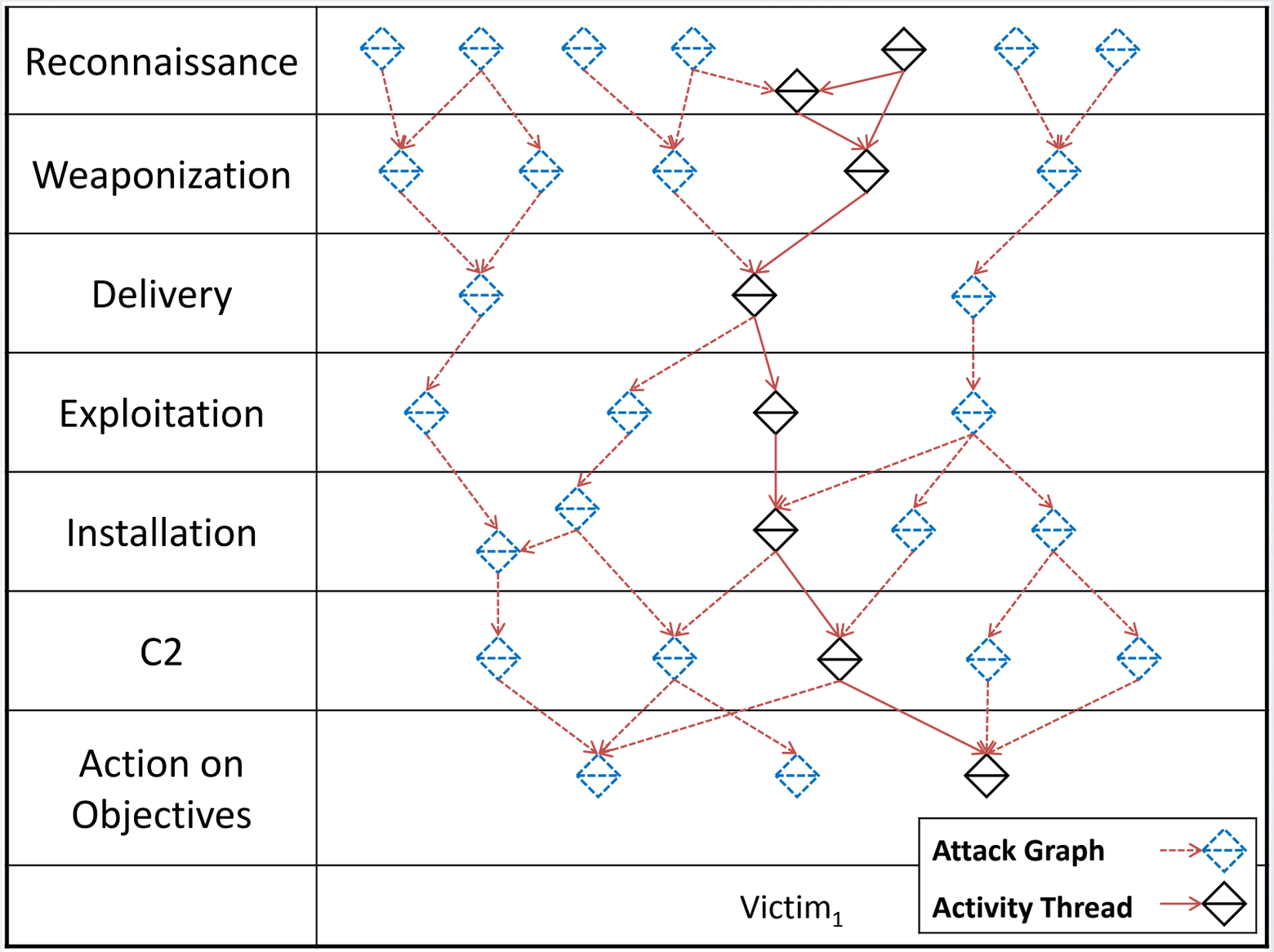
- Remove the details
- Focus on common recurring elements
- Check among known activity threads

		Process Features
Reconnaissance		Web search for “network administrator” [derived from event 2]
Weaponization		
Delivery		Email with trojanized attachment delivered [derived from event 3]
Exploitation		Specific local exploit (e.g., CVE-YYYY-XXX) [derived from event 4]
Installation		
C2		HTTP Post from victim [derived from event 6]
Action on Objectives		

ACTIVITY THREAD

Support for for analytical hypothesis checking

- Support through other approaches
- E.g. Attack graphs



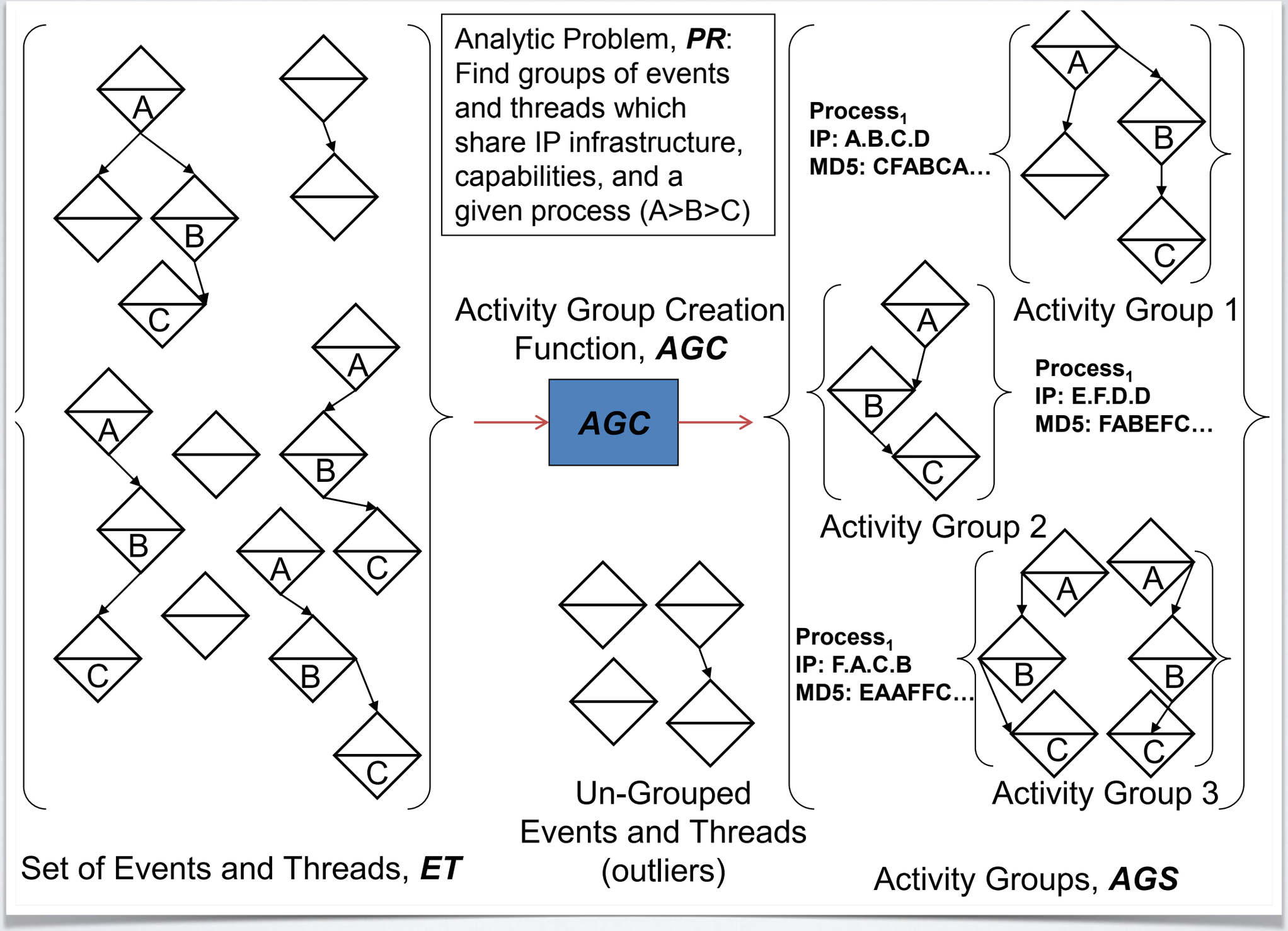
ACTIVITY GROUPS

Extract knowledge related to activity groups through a process:

- **Step 1: Analytic Problem** The particular analytic problem to be solved through grouping
- **Step 2: Feature Selection** The event features and adversary processes used to form the basis of classification and clustering are selected
- **Step 3: Creation** Activity groups are created from the set of events and threads

  Step 4: Growth As new events flow into the model, they are classified into the Activity Groups
- **Step 5: Analysis** Activity groups are analyzed to address the analytic problem(s) defined
- **Step 6: Redefinition** Activity groups need to be redefined from time-to-time to maintain their accuracy

ACTIVITY GROUPS



ACTIVITY GROUPS

